Software Engineeering

Lab-05

Name:Punith K

SRN:PES2UG24CS383

Section:G

# Museuw_catelog:

# Output screenshots:

# Initial  reports:

```
(venv) C:\Users\Punith K\Documents\se_handout file>python museum_catalog.py
on display
135000
catalog backup complete

(venv) C:\Users\Punith K\Documents\se_handout file>python -m flake8 museum_catalog.py
museum_catalog.py:2:1: F401 'datetime' imported but unused
museum_catalog.py:6:80: E501 line too long (120 > 79 characters)
museum_catalog.py:11:80: E501 line too long (158 > 79 characters)
museum_catalog.py:16:80: E501 line too long (98 > 79 characters)
museum_catalog.py:24:1: E303 too many blank lines (3)
museum_catalog.py:25:10: E225 missing whitespace around operator
museum_catalog.py:26:80: E501 line too long (86 > 79 characters)
museum_catalog.py:32:80: E501 line too long (84 > 79 characters)

(venv) C:\Users\Punith K\Documents\se_handout file>python -m bandit -r museum_catalog.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.12
Run started:2026-10-16 04:25:23.806216+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess
   Location: .\museum_catalog.py:3:0
2       import datetime
3       import subprocess
4

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'm4seum!'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\museum_catalog.py:7:19
6       conn.execute("CREATE TABLE artifacts (id INTEGER PRIMARY KEY, title TEXT, era TEXT, value INTEGER, on_display INTEGER)")
```

```
--------------------------------------------------
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\museum_catalog.py:11:17
10      def addArtifact(title, era, value, on_display=0):
11          conn.execute("INSERT INTO artifacts (title, era, value, on_display) VALUES ('" + title + "', '" + era + "', " + str(value) + ", " + str(on_displ
ay) + ")")
12          conn.commit()

--------------------------------------------------
>> Issue: [B607:start_process_with_partial_path] Starting a process with a partial executable path
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b607_start_process_with_partial_path.html
   Location: .\museum_catalog.py:37:4
36      def backupNote():
37          subprocess.call("echo catalog backup complete", shell=True)
38

--------------------------------------------------
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True seems safe, but may be changed in the future, consider rewriting wi
thout shell
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
   Location: .\museum_catalog.py:37:4
36      def backupNote():
37          subprocess.call("echo catalog backup complete", shell=True)
38

--------------------------------------------------

Code scanned:
        Total lines of code: 34
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
```

```
        Total lines of code: 34
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 4
                Medium: 1
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 2
                High: 3
Files skipped (0):

(venv) C:\Users\Punith K\Documents\se_handout file>python -m pylint museum_catalog.py
************* Module museum_catalog
museum_catalog.py:6:0: C0301: Line too long (120/100) (line-too-long)
museum_catalog.py:11:0: C0301: Line too long (158/100) (line-too-long)
museum_catalog.py:1:0: C0114: Missing module docstring (missing-module-docstring)
museum_catalog.py:10:0: C0116: Missing function or method docstring (missing-function-docstring)
museum_catalog.py:10:0: C0103: Function name "addArtifact" doesn't conform to snake_case naming style (invalid-name)
museum_catalog.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
museum_catalog.py:15:0: C0103: Function name "displayStatus" doesn't conform to snake_case naming style (invalid-name)
museum_catalog.py:17:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
museum_catalog.py:15:31: W0613: Unused argument 'curator' (unused-argument)
museum_catalog.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
museum_catalog.py:24:0: C0103: Function name "totalValue" doesn't conform to snake_case naming style (invalid-name)
museum_catalog.py:31:0: C0116: Missing function or method docstring (missing-function-docstring)
museum_catalog.py:31:0: C0103: Function name "moveToDisplay" doesn't conform to snake_case naming style (invalid-name)
museum_catalog.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
museum_catalog.py:36:0: C0103: Function name "backupNote" doesn't conform to snake_case naming style (invalid-name)
museum_catalog.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
museum_catalog.py:2:0: W0611: Unused import datetime (unused-import)

-------------------------------------------------------------------
Your code has been rated at 4.85/10 (previous run: 10.00/10, -5.15)


(venv) C:\Users\Punith K\Documents\se_handout file>
```

# Updated Code:

```python
"""Museum artifact catalog with safer database handling."""

import sqlite3

conn = sqlite3.connect(":memory:")
conn.execute(
    """CREATE TABLE artifacts (
        id INTEGER PRIMARY KEY,
        title TEXT NOT NULL,
        era TEXT NOT NULL,
        value INTEGER NOT NULL CHECK (value >= 0),
        on_display INTEGER NOT NULL DEFAULT 0
            CHECK (on_display IN (0, 1))
    )"""
)


def add_artifact(
    title: str, era: str, value: int, on_display: int = 0
) -> None:
    """Add an artifact using parameterized SQL and validated values."""
    if not title.strip():
        raise ValueError("Artifact title cannot be empty.")
    if not era.strip():
        raise ValueError("Artifact era cannot be empty.")
    if isinstance(value, bool) or not isinstance(value, int) or value < 0:
        raise ValueError(
            "Artifact value must be a non-negative integer."
        )
    if on_display not in (0, 1):
        raise ValueError("on_display must be 0 or 1.")

    conn.execute(
        "INSERT INTO artifacts (title, era, value, on_display) "
        "VALUES (?, ?, ?, ?)",
```

```
def add_artifact(
        (title, era, value, on_display),
    )
    conn.commit()


def display_status(
    artifact_id: int, curator: str | None = None
) -> str:
    """Return display status or an error for an unknown artifact ID."""
    del curator  # Retained for compatibility with the original demo.
    row = conn.execute(
        "SELECT on_display FROM artifacts WHERE id = ?",
        (artifact_id,),
    ).fetchone()
    if row is None:
        raise ValueError(f"No artifact found with id {artifact_id}.")
    return "on display" if row[0] == 1 else "in storage"


def total_value(era: str) -> int:
    """Return the combined value of artifacts from the requested era."""
    row = conn.execute(
        "SELECT COALESCE(SUM(value), 0) FROM artifacts WHERE era = ?",
        (era,),
    ).fetchone()
    return int(row[0])


def move_to_display(artifact_id: int) -> None:
    """Move an artifact to display if the ID exists."""
    cursor = conn.execute(
        "UPDATE artifacts SET on_display = 1 WHERE id = ?",
        (artifact_id,),
    )
```

```
    conn.commit()
    if cursor.rowcount == 0:
        raise ValueError(f"No artifact found with id {artifact_id}.")


def backup_note() -> None:
    """Print the catalog backup notice."""
    print("catalog backup complete")


def main() -> None:
    """Run a small catalog demonstration."""
    add_artifact("Bronze Mirror", "Chola", 120000)
    add_artifact("Palm Manuscript", "Vijayanagara", 80000, 1)
    add_artifact("Terracotta Lamp", "Chola", 15000)
    move_to_display(1)
    print(display_status(1, "Dr. Rao"))
    print(total_value("Chola"))
    backup_note()


if __name__ == "__main__":
    main()
```

# Updated Reports:

```
(venv) C:\Users\Punith K\Documents\se_handout file>python museum_catalog.py
on display
135000
catalog backup complete

(venv) C:\Users\Punith K\Documents\se_handout file>python -m flake8 museum_catalog.py

(venv) C:\Users\Punith K\Documents\se_handout file>python -m bandit -r museum_catalog.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.12
Run started:2026-10-16 04:26:52.164523+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 75
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):

(venv) C:\Users\Punith K\Documents\se_handout file>python -m pylint museum_catalog.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.85/10, +5.15)
```

| Issue | Type | Line(s) | Description | Fix Approach |
|---|---|---|---|---|
| SQL injection risk | Security | Original addArtifact() | SQL queries were constructed using string concatenation, allowing malicious input to alter a query. | Use parameterized SQL queries with ? placeholders. |
| Unsafe subprocess usage | Security | Original backupNote() | Used subprocess.call(..., shell=True), which can introduce command-injection risks. | Remove the unnecessary shell command and print the backup notice directly. |
| Hard-coded password | Security | Original password declaration | The curator password was hard-coded in the source code and was not used for authentication. | Remove the unused password; use secure configuration if authentication is implemented. |
| Missing input validation | Bug | Original addArtifact() | Empty titles, invalid values, or invalid display-status values could be accepted. | Validate title, era, value, and display status before inserting records. |
| Missing artifact check | Bug | Original displayStatus() | Accessing row[0] when no artifact | Check whether the query returned a row |

| | | | | |
|---|---|---|---|---|
| | | | exists could cause a TypeError. | and raise a clear error if the ID is missing |
| Unused import | Code quality | Original import section | The subprocess module remained imported after the backup function was changed to use print() | Remove import subprocess. |
| Long lines | Style | Lines 18, 30 in the reported version | Flake8 reported lines exceeding the 79-character limit. | Split long statements across multiple lines using parentheses. |
| Excess blank lines | Style | Lines 66, 72 in the reported version | Flake8 reported too many blank lines between top-level definitions. | Keep exactly two blank lines between top-level functions. |
| Inconsistent naming | Maintainability | Original function definitions | Function names used camelCase, such as addArtifact() and totalValue(), instead of Python's conventional snake_case. | Rename functions to add_artifact() and total_value(). |
| Inefficient total calculation | Performance | Original totalValue() | Retrieved each value and added it in a Python loop instead of using SQL aggregation. | Use SELECT SUM(value) with COALESCE to calculate the total in the database. |